

Automate a control — and govern with NIST CSF 2.0

Session 12 – Security automation, AI

Exercise 12 · Session 12 lab · Estimated time: 90–120 min

Write your answers in the answer document `SKY2100_Exercise12_Answers.docx`. You spent eleven sessions building security by hand. Today you take one step toward running it at scale: automate a single control, then step back and govern – mapping your whole term’s work onto the NIST CSF 2.0 functions and reflecting on the role of AI.

Caution: Run scripts only against your own VM. A script that enforces a setting can also break things – test it, and read it before you run it.

1 Automate one control

▷ Turn one manual control from this term into a small script that checks (and optionally enforces) a setting. Pick one, e.g.:

```
# Example: check that UFW is active and SSH is limited
sudo ufw status | grep -q "Status: active" \
&& echo OK || echo "FAIL: firewall off"
# Example: check a key file is not world-readable
test "$(stat -c %A /path/to/secret)" = "-rw----" && echo OK || echo "FAIL:
perms"
```

▷ What does your script check, and what would it do (or alert) on failure? Why is a script better than checking by hand across many machines?

AHA. You spent eleven weeks applying controls by hand on one VM. The script you just wrote does the same check in a second, and it would do it identically on a hundred machines without getting tired or skipping one. That is the difference between governance and automation: governance decides the rule, such as “the firewall must be on”, and automation enforces it consistently at a scale no person can match. Keep one caution in view. The same script that enforces a setting everywhere can also break things everywhere if the rule is wrong, and passing your own check is not the same as being secure, since a checkbox cannot stop an attack it was never written to look for.

2 Map your term to NIST CSF 2.0

▷ Place each of your S1–S11 deliverables under the right CSF 2.0 function

— Govern, Identify, Protect, Detect, Respond, Recover — in the mapping table of the answer document (session + what you did).

3 Governance reflection

▷ Governance sets the rules; automation enforces them. Give one example of a policy for your service (e.g. “all backups must be off-site”), and how policy as code could enforce it automatically.

▷ For one CSF function, name the single best thing you did this term and one gap that still remains.

4 AI reflection

▷ Name one way AI could help defend your service (e.g. anomaly detection, alert summarisation), and one new risk that deploying or using AI introduces (e.g. prompt injection, hallucinated output).

- ▷ Why does “a human stays accountable” remain true even when AI does the work? (one line)

5 Risk register & assurance (the auditor’s view)

A control is only worth what you can justify and evidence. This is the governance work a cloud-risk or audit team does on top of the technical build — and it uses the CSA **Risk, Audit & Compliance** domain (Domain 3) you have not yet touched.

▷ **Risk register.** Record three cloud risks for your service in the risk register of the answer document (CSA Domain 3, p. 65–66). Columns: asset / service, threat, risk level, owner, review. Derive the level as **Risk = impact × likelihood** and pick critical / high / moderate / low — for example: Nextcloud data on the VM / ransomware / High (high × moderate) / you / annual.

▷ **Risk treatment.** For your highest risk, choose one of the four options — mitigate / transfer / avoid / accept — name the control, and state the **residual risk** left after it (CSA p. 62). Who should formally accept that residual risk?

▷ **Assurance.** You cannot audit a hyperscaler yourself — you read its assurance report instead. Name one report you would request before trusting a provider with this data, and one thing you would check in it: a **SOC 2 / ISAE 3402** attestation, an **ISO/IEC 27001** certificate, **BSI C5**, or the provider’s **CSA STAR** entry. For your choice, say whether it is an audit (independent opinion, high assurance) or an attestation (a statement of posture, moderate assurance) — CSA Domain 3, p. 73–76.

6 Cloud transfer: Microsoft Learn

▷ Work through “Introduction to Azure Policy” and note how a policy is defined, assigned and enforced (audit / deny / remediate).

learn.microsoft.com/training/modules/intro-to-azure-policy

▷ How is an Azure Policy that denies non-compliant resources an example of “governance + automation” from the lecture? One or two lines.

7 Azure reflection

▷ NIST CSF 2.0 added **Govern** as a new central function. In your own words, what does Govern do that Protect/Detect/Respond/Recover do not?

▷ “Compliance is not security.” Give one example from this term of something that could pass a checkbox audit yet still be insecure.

8 Knowledge check

1. Why does manual security “not scale” in the cloud?

Hint: Hundreds of resources change constantly — manual work is slow and inconsistent.

2. Distinguish **automation** from **governance**.

Hint: One enforces controls at scale; one sets the rules and the accountability.

3. Define **governance** (CSA / ISACA).

Hint: Policies, procedures and controls — for transparency and accountability.

4. Name the six functions of **NIST CSF 2.0**, and which one is new in 2.0.

Hint: Identify, protect, detect, respond, recover — and the new sixth one.

5. What is **policy as code**, and how does it relate to governance?

Hint: Security rules written as machine-readable definitions the platform enforces.

6. What does **CSPM** automate, and **SOAR**?

Hint: One finds misconfigurations continuously; one automates incident response.

7. Give two benefits and two risks of security automation.

Hint: Speed and consistency — but a bad rule applied everywhere, instantly.

8. Name one way AI helps defenders and one way it helps attackers.

Hint: Defenders triage faster; attackers scale phishing and find flaws quicker.

9. What is **prompt injection**, and which earlier topic is it related to?

Hint: Malicious input that hijacks the AI's instructions — the injection family from S8.

10. What are CSF **Tiers** and **Profiles** used for?

Hint: How mature your practice is, versus current-state-against-target.

11. Why is “compliance is not security” an important distinction?

Hint: Meeting requirements at a point in time, versus actually resisting attackers.

12. Map each CSF function (except Govern) to a session of this course.

Hint: Identify=S1, Protect=S6–8, Detect=S9, Respond=S10, Recover=S11.

13. Define **residual risk**, and name the four risk-treatment options.

Hint: What is left after the control; the four options are the ones from the risk-register task.

14. What is the difference between an **audit** and an **attestation** (e.g. SOC 2), and which gives higher assurance?

Hint: Independent opinion versus a statement of posture — one of them carries more weight.

Progress check: Discuss your answers in the group, then talk the teacher through them verbally at the next session only to track progress; nothing is handed in, signed or graded.

Solutions

Work through the lab first, then check here. Model answers are indicative — equivalent reasoning is fine.

Note: Model answers are indicative – accept equivalent reasoning. Multiple-choice answers are in **bold**.

Knowledge check

1. At cloud scale there are hundreds of resources created and destroyed constantly. Manual work is slow, inconsistent and error-prone (most breaches start with a misconfiguration), and humans cannot watch everything in real time – attacks move faster than people.
2. **Automation** is how security is enforced at scale – machines applying controls consistently. **Governance** is what the rules are and who decides – policy, roles, accountability and risk. Governance sets policy; automation enforces it.
3. Governance is a framework of **policies, procedures and controls** promoting transparency and accountability, covering strategic guidance, risk management, compliance and cost control (CSA p. 28). ISACA: it sets direction through prioritisation, decision-making and monitoring.
4. **Govern, Identify, Protect, Detect, Respond, Recover. Govern** is the new sixth function added in CSF 2.0 (2024), placed centrally.
5. **Policy as code** expresses security rules as machine-readable definitions the platform enforces automatically (e.g. “no public storage”). It makes governance executable – a written policy becomes an enforced rule on every deployment.
6. **CSPM** automates continuous configuration/compliance checking (finding misconfigurations). **SOAR** automates incident response steps via playbooks (enrich, block, isolate, ticket).
7. **Benefits:** speed, scale, consistency, fewer human errors (any two). **Risks:** a bad rule applied everywhere instantly; reduced visibility/over-reliance; attackers automate too; automation failures (any two). Keep humans in the loop for high-impact actions.
8. **Defenders:** anomaly detection, alert triage/summarisation, faster investigation (Comer p. 239; CSA p. 143). **Attackers:** deepfakes, automated/evasive attacks, faster reconnaissance (Comer p. 239).
9. **Prompt injection** is malicious input that hijacks an AI’s instructions – the same injection family as SQLi/XSS from S8 (application security), aimed at a model. Validate input and never trust output blindly.
10. **Tiers** describe how mature your practices are (Partial→Adaptive, Tier 1–4). **Profiles** compare your current state to a target state; the gap is your roadmap. You choose a target matching your risk appetite.
11. Compliance = meeting requirements at a point in time; security = actually resisting attackers continuously. You can be compliant and breached – a checkbox does not stop a novel attack. Use frameworks as a floor, not a ceiling.
12. **Identify** = S1 (cloud, shared responsibility, assets/risk); **Protect** = S6 (TLS), S7 (hardening/access), S8 (secure apps/WAF); **Detect** = S9 (monitoring & IDS); **Respond** = S10 (incident response); **Recover** = S11 (resilience & backup). (Govern = S12, overarching.)
13. **Residual risk** is the risk that remains after the chosen control is applied. The four treatment options are **mitigate** (reduce with a control), **transfer** (e.g. insurance or a provider), **avoid** (do not do the risky thing) and **accept** (formally, by an accountable owner). (CSA Domain 3, p. 62.)
14. An **audit** is an independent examination that ends in an opinion against a defined standard (e.g. ISO/IEC 27001 certification) — high assurance. An **attestation** (e.g. SOC 2 / ISAE 3402) is a statement of the provider’s control posture, examined by an auditor but

scoped and described by the provider — moderate assurance. The audit gives the higher assurance. (CSA Domain 3, p. 73–76.)

Lab checkpoints

- **Automation:** any sensible check/enforce script is acceptable (firewall active, file permissions, encryption on, a required config). Reward output that clearly reports OK/FAIL and an explanation of why a script scales better than manual checking across many machines.
- **CSF mapping:** expect Identify = S1, Protect = S6/S7/S8, Detect = S9, Respond = S10, Recover = S11, and Govern = S12 (this lecture – policy, risk, accountability). The insight is that the whole course is the CSF lifecycle.
- **Governance reflection:** a concrete policy (e.g. “backups off-site”, “disks encrypted”) plus how policy as code / Azure Policy would enforce it (deny or auto-remediate).
- **AI reflection:** one defensive use (anomaly detection, summarisation) and one real risk (prompt injection, hallucination, data leakage). A human stays accountable because models err and accountability cannot be delegated to software.

Risk register & assurance (model answers)

- **Risk register:** accept any sensible row where the level follows from impact $\times$ likelihood, with a named owner and a review date, e.g. Nextcloud data on the VM / ransomware / High (high $\times$ moderate) / owner: ops / review: annual. The point is the structure, not the exact wording (CSA Domain 3, p. 65–66).
- **Risk treatment:** one of mitigate / transfer / avoid / accept; the **residual risk** is what remains after the control (e.g. immutable backups mitigate ransomware, but residual risk = the most recent unbacked-up changes). The **business owner** formally accepts residual risk, after a cost–benefit decision, and it is re-reviewed periodically (CSA p. 62).
- **Assurance:** a credible answer names a provider report and classifies it — **SOC 2 / ISAE 3402** = attestation (moderate assurance, a statement of posture); an **ISO/IEC 27001** certificate or a **BSI C5** report; or a **CSA STAR** entry. Key insight: you cannot audit a hyperscaler yourself, so you inherit assurance by reading its report — but inheritance does not shift your responsibility for your own layer (CSA Domain 3, p. 73–76).

Cloud transfer & reflection

- **Azure Policy deny = governance + automation:** the policy (governance) states the rule; Azure automatically blocks non-compliant resources at creation (automation). Written intent becomes enforced reality with no human in the loop – the lecture’s core idea.
- **What Govern adds:** Govern sets strategy, roles, policy, risk appetite and oversight – it decides what matters and who is accountable, which the operational functions (Protect/Detect/Respond/Recover) then carry out. It is the new central function in CSF 2.0.
- **Compliance $\neq$ security example:** e.g. a system that “has backups” (ticks the box) but whose backups were never restore-tested (S11), or a WAF in detection-only mode (S8) that logs but blocks nothing – compliant on paper, exposed in practice.

References

CSA Security Guidance v5, **Domain 2: Cloud Governance and Strategies** (p. 28–29, verified): governance definition and ISACA framing, frameworks (ISO/IEC 38500, COBIT, ISO/IEC 27014) and laws (GLBA, SOX, HIPAA, GDPR) (p. 28), cloud adoption drivers, risk appetite and security-by-design (p. 29); Domain 6.5 GenAI for security monitoring (p. 143). **NIST Cybersecurity Framework (CSF) 2.0**, published February 2024 (verified, June 2026): six core functions – Govern,

Identify, Protect, Detect, Respond, Recover – with Govern newly added and central; Core, Tiers and Profiles. Comer, The Cloud Computing Book, Ch. 17.8 – AI for attackers and defenders (p. 239); Ch. 10 – orchestration & replication. MS Learn: Govern your Azure resources with Azure Policy (verified, June 2026).